

Clase 271 — Seguridad de Bluetooth y BLE

Parte: **13 — Seguridad móvil, IoT e inalámbrica** · Fuente: *Practical IoT Hacking* (Chantzis et al.) y especificación Bluetooth SIG 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Auditar dispositivos Bluetooth Low Energy (BLE), el protocolo inalámbrico dominante en wearables, cerraduras, sensores y gadgets IoT. El alumno entenderá la pila BLE (GAP/GATT), los modos de emparejamiento y sus debilidades, y aprenderá a escanear, enumerar servicios/características, interceptar y reproducir tramas, y manipular valores de un dispositivo **propio** con herramientas como `bluetoothctl`, `gatttool`, `bettercap` y un sniffer (nRF/Ubertooth).

⚠️ **Nota ética:** interactúa solo con dispositivos BLE de tu propiedad o autorizados. Interceptar, manipular o denegar servicio a dispositivos ajenos (p. ej. cerraduras o dispositivos médicos de terceros) es ilegal y peligroso.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Describir** la pila BLE: roles GAP, servicios y características GATT, y advertising.
2. **Escanear** y enumerar dispositivos y sus servicios/características.
3. **Explicar** los modos de emparejamiento (Just Works, Passkey, OOB) y sus riesgos.
4. **Leer y escribir** características de un dispositivo propio con gatttool/nRF Connect.
5. **Capturar** tráfico BLE con un sniffer y analizarlo en Wireshark.
6. **Identificar** controles ausentes (falta de cifrado, autorización en el cliente).

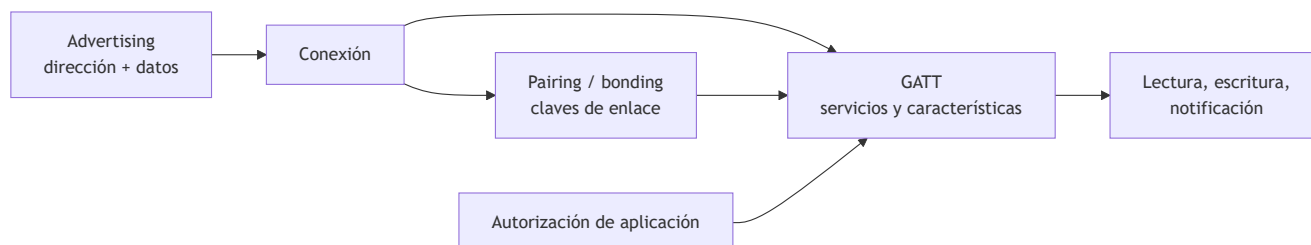
📖 Temas

#	Tema	Por qué importa
1	Pila BLE y roles GAP	Base de cómo se conectan los dispositivos
2	GATT: servicios y características	Donde vive la funcionalidad y los datos
3	Advertising y descubrimiento	Primer paso de la enumeración
4	Emparejamiento y cifrado	Determina si el tráfico es interceptable
5	Enumeración con gatttool/nRF	Mapear e interactuar con el dispositivo
6	Sniffing con nRF/Ubertooth	Capturar el tráfico real
7	Replay y manipulación	Demostrar impacto en laboratorio

Explicación en profundidad

En BLE, descubrir un servicio no concede autorización

Bluetooth Classic y BLE comparten familia, pero difieren en perfiles y uso. En BLE, advertising anuncia presencia y datos; una conexión descubre servicios y características GATT; seguridad de enlace depende del emparejamiento y sus capacidades; y la aplicación todavía debe autorizar operaciones sensibles. Una característica legible no es vulnerable por definición: importa el dato, el vínculo y el contexto.



«Just Works» puede ser apropiado cuando no existe interfaz, pero no autentica suficientemente frente a MITM en todos los escenarios. Numeric Comparison y passkey dependen de capacidades y verificación humana. LE Secure Connections mejora el intercambio criptográfico; no arregla un token estático enviado como valor GATT.

Las direcciones privadas reducen seguimiento, aunque payload, ritmo, nombre y comportamiento pueden seguir correlacionando. Capturar tráfico de una conexión propia exige registrar versión, método de pairing y claves disponibles; sin ellas, ver advertising no equivale a descifrar la sesión.

Caso razonado: cerradura con enlace cifrado

Una cerradura usa enlace BLE cifrado, pero acepta el mismo comando de apertura después de conectar cualquier teléfono emparejado. Falta autorización por usuario y frescura a nivel de aplicación. Se añade identidad, nonce, política de rol y registro; el cifrado de enlace permanece como una capa.



Glosario operativo

Término	Definición útil
Advertising	Emisión BLE para descubrimiento y datos breves.
GATT	Modelo de servicios, características y operaciones BLE.
Pairing	Proceso que establece parámetros y claves de seguridad.
Bonding	Conservación de claves para conexiones futuras.
Dirección privada	Dirección que rota para reducir seguimiento, con límites.



Criterio de dominio

El alumno domina BLE cuando separa descubrimiento, enlace y autorización, identifica el método de pairing, prueba solo periféricos propios y propone protección contextual para una característica sensible.

Definiciones y características

- **GAP (Generic Access Profile):** define roles (central/periférico) y el advertising. Característica: controla descubrimiento y conexión.
- **GATT (Generic Attribute Profile):** organiza datos en servicios y características con handles y UUID. Característica: es la superficie funcional del dispositivo.
- **Característica (characteristic):** valor con propiedades (read/write/notify). Característica: leerla/escribirla puede cambiar el estado del dispositivo.
- **Just Works:** emparejamiento sin autenticación de usuario. Característica: vulnerable a MITM; muy común en IoT barato.
- **nRF Connect / nRF52840 dongle:** app y hardware para escanear, interactuar y sniffear BLE. Característica: accesibles y bien documentados.
- **bettercap (módulo BLE):** framework que enumera y manipula dispositivos BLE. Característica: automatiza recon y escritura de características.

Herramientas y preparación

- **Adaptador BLE** (interno o dongle CSR/nRF), **nRF52840 dongle** o **Ubertooth One** para sniffing.
- **BlueZ** (`bluetoothctl` , `gatttool` , `hcitool`), **bettercap**, **nRF Connect** (móvil/desktop), **Wireshark**.

```
# Escaneo y enumeración con BlueZ
sudo bluetoothctl
[bluetooth]# scan on
gatttool -b AA:BB:CC:DD:EE:FF --primary          # listar servicios
gatttool -b AA:BB:CC:DD:EE:FF --characteristics  # listar características
gatttool -b AA:BB:CC:DD:EE:FF --char-read -a 0x0025

# bettercap
sudo bettercap -eval "ble.recon on"
```

Laboratorio guiado

1. **Escanea** con `bluetoothctl scan on` o `bettercap ble.recon on` y localiza tu dispositivo BLE propio.
2. **Enumera GATT:** con `gatttool` o `nRF Connect` lista servicios y características, anotando handles, UUID y propiedades (read/write/notify).
3. **Lee valores:** lee características legibles y correlaciona con el estado del dispositivo (p. ej. nivel de batería).
4. **Escribe valores:** en tu dispositivo propio, escribe una característica de control y observa el efecto (encender/apagar, cambiar color).
5. **Habilita notificaciones:** suscríbete a una característica `notify` y captura los eventos.
6. **Sniff:** con el `nRF52840/Ubertooth` captura una conexión y ábrela en `Wireshark`; comprueba si el enlace está cifrado.
7. **Replay:** si el dispositivo acepta comandos sin autenticación, reproduce una escritura capturada para demostrar el impacto.
8. **Documenta** el mapa GATT y las debilidades encontradas.

Ejercicios

1. Enumera todos los servicios y características de un dispositivo BLE propio.
2. Identifica qué característica controla una función concreta.
3. Cambia el estado del dispositivo escribiendo una característica.
4. Captura tráfico BLE y determina si el emparejamiento usa Just Works.
5. Suscríbete a notificaciones y registra tres eventos.
6. Enumera las debilidades del dispositivo (falta de cifrado/autorización).

Reto verificable

Toma un dispositivo BLE **propio** (p. ej. una bombilla o candado de juguete) y demuestra control no autenticado: identifica la característica de control y modifícala para cambiar su estado sin usar la app oficial. **Criterio de aceptación:** documentas el handle/UUID exacto, el valor escrito y evidencia del cambio físico, y concluyes si el dispositivo protege o no sus comandos.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No aparece en el escaneo	No está en modo advertising; despiértalo o acércalo
<code>gatttool</code> no conecta	La app oficial lo tiene conectado; ciérrala y reintenta
Escritura sin efecto	Handle equivocado o requiere formato/valor concreto; revisa propiedades
Sniffer no captura la conexión	Perdió el evento de conexión; reinicia el sniffer antes de conectar
Tráfico ilegible en Wireshark	Enlace cifrado; necesitas la LTK o capturar el emparejamiento

Preguntas frecuentes

? ¿Puedo interceptar cualquier tráfico BLE? Solo si capturas el emparejamiento o el enlace no está cifrado. Con Just Works y sin cifrado adicional, el tráfico suele ser legible; con emparejamiento seguro necesitas la clave.

? ¿Por qué tantos dispositivos BLE son inseguros? Algunos productos usan Just Works y confían demasiado en que solo la app oficial actuará como cliente. Si una característica sensible carece además de permisos de enlace y autorización de aplicación, una central dentro de alcance podría intentar operarla; debe comprobarse en el periférico propio.

? ¿Sirve un dongle barato para empezar? Para escanear e interactuar sí. Para sniffear conexiones necesitas hardware específico como el nRF52840 o Ubertooth One.

Referencias

- Bluetooth SIG — especificación Core y GATT: <https://www.bluetooth.com/specifications/>
- Nordic nRF Connect: <https://www.nordicsemi.com/Products/Development-tools/nrf-connect-for-desktop>

- bettercap BLE: <https://www.bettercap.org/modules/ble/>
- *Practical IoT Hacking*, caps. de BLE — Chantzis et al.



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 270 — Ataques a RFID y NFC](#)



Siguiente clase

[Clase 272 — Ataques WiFi avanzados: Evil Twin y PMKID](#)